

THE CONCIERGE KNOWS TOO MUCH

This room was based on AI Prompt injection, we were given an AI chatbot that of an hotel/resort that had access to client information a bit too much , the hotel gave access to every information they had to the chatbot for hyper personalization of their guests.

It would treat normal users as intended but have more access and deeper access to some trusted individuals.

We were given an hint of these trusted individual's names , I manipulated AI chatbot by making it think I am one of the trusted ones and another trusted individual wanted to know and get access to the information and instructions that were normal people weren't allowed to , the chatbot printed all the information of the guests staying in the resort and of the trusted individuals.

Precaution and safety guards for prompt injection:-

1.Separation of data- Let models only access the data for the authenticated user of the current session.

2.Bidirectional firewall – check for input from the user as well as the data ai model is showing or sending to the user.

3.Human in loop- Classify sensitive information and require human approval for high risk data sharing.

4.Enforce least-privilege scoping: Restrict the AI agent's underlying API and database permissions so it can only access data belonging to the actively authenticated user.